

Does Stenwatch's scoring find the vulnerabilities attackers actually use?

A point-in-time backtest against CISA's Known Exploited Vulnerabilities catalogue · Stenwatch
e7516c9 + uncommitted changes · run 2026-10-09 13:10 · Diljot Singh Johal

1. Summary

What was tested. On six start dates, six months apart, we ranked every CVE that was not yet known to be exploited, using only what was knowable that day. Then we counted how many were added to CISA's known-exploited list over the next six months (257 in all) and how much reading each method needed to find them.

- **The Attend queue is small and efficient, but it is not more complete than the critical list.** Attend (EPSS at or above 0.1) holds 6.1% of all CVEs and found **40%** of the later-exploited ones (95% interval 34% to 46%). The usual CVSS 9 and above list holds 13.0% and found **36%** (30% to 42%). The difference in what they found is not statistically significant ($p = 0.329$), but Attend does it from a queue 2.1 times smaller, so each CVE read is 2.4 times as likely to be a hit.
- **At the same queue size the Stenwatch ranking is clearly better.** Reading down the Stenwatch score for as many CVEs as the critical list holds finds 50% of the exploited CVEs, against 36% for the critical list itself. For a queue the size of Attend, a severity ranking finds only 16% against Attend's 40%.
- **The advantage is at small review budgets, and it reverses in the long tail.** After reading the first 1% of the list the Stenwatch score has found 21% against 2% for CVSS; after 10%, 46% against 30%. To reach 80% of the exploited CVEs, CVSS needs 42.5% of the list and the Stenwatch score 58.2%. The two gain curves cross at about 25% of the list: reading further than that, the CVSS ranking is ahead. Overall AUC is 0.744 for CVSS and 0.720 for the Stenwatch score. 45% of the later-exploited CVEs had an EPSS below 0.01 on the origin day, and no probability-led ranking can place them early.
- **Most CISA additions cannot be predicted six months ahead.** 62% of the 711 CVEs CISA added during the windows had not even been published on the origin day. They are out of reach of any ranking; they are caught once CISA lists them, which is what Stenwatch's KEV feed is for.

A correction. An earlier exploratory run reported that the Attend queue caught about 70% against about a third for the critical list. That result is withdrawn. It came from a local database that was missing most CVEs published in 2024 and 2025, which silently removed the hardest-to-find exploited CVEs from the test. This report uses a complete database and replaces it. Please do not quote the 70% figure.

Read this before quoting the numbers. 257 positives are enough to separate large differences but not to give tight percentages; the intervals show the uncertainty. The test measures the global scoring signals only. It does not test the KEV flag, ransomware use,

threat-group matching or your asset list, which have no point-in-time history. See section 7.

2. Terms used

Term	Meaning
CVE	A public identifier for one software vulnerability, such as CVE-2024-12345.
CVSS	A 0 to 10 severity score for how bad a flaw could be. It says nothing about whether anyone is using it.
EPSS	A 0 to 1 probability, published daily by FIRST, that a CVE will be exploited in the next 30 days.
KEV	CISA's catalogue of vulnerabilities known to be exploited in the wild. Used here as the answer key.
Queue	The CVEs a rule selects for attention, for example every CVE with EPSS at or above 0.1.
Recall	Of the CVEs that were later exploited, the share a queue contained.
Hit rate	Of the CVEs in a queue, the share that were later exploited. Lift is the hit rate divided by the base rate.
Review budget	How far down a ranked list a team can read, as a share of all CVEs.

3. Questions and hypotheses

Stenwatch ranks vulnerabilities by risk = likelihood × impact, where likelihood leans on EPSS and impact on CVSS. The question is whether that ranking would have pointed a team at vulnerabilities attackers went on to use, better than the common practice of working down the CVSS list. Two hypotheses were written before the complete-data run:

- **H1.** A ranking by EPSS × CVSS finds later-exploited CVEs with less review effort than a ranking by CVSS alone. **Verdict: Partly supported.** It holds at small review budgets (the first 1%, 5% and 10% of the list) but not over the whole list: CVSS reaches 80% sooner and has the higher AUC.
- **H2.** The Attend queue catches more later-exploited CVEs than a critical-severity queue (CVSS 9 and above) of similar or smaller size. **Verdict: Partly supported.** Attend caught 40% against 36% (not a significant difference) from a queue 2.1 times smaller. "Catches more" is not shown; "catches as many from far less" is.

The first exploratory run suggested stronger results than these (section 1, correction). The windows, thresholds and measures below were fixed before the complete-data run and were not changed afterwards. The thresholds are the product's own defaults (profile.example.yaml),

not values tuned on this data. The equal-size comparison (6.5) was added after seeing the first results, because comparing queues of different sizes is unfair to both; treat it as exploratory.

4. Data and provenance

Data	What it is	Used for	Point in time?
EPSS daily files	FIRST's exploit-probability score for every CVE, one file per day from epss.empiricalsecurity.com. Six snapshots, one per window start (SHA-256 of each in section 9).	Ranking score	Yes: the file of the origin day
CISA KEV catalogue	1,739 entries, first added 2021-11-03, latest 2026-10-08, with the date each CVE was added.	Labels (what counts as exploited, and when)	Yes: the date added decides the window
NVD CVE records	400,841 CVEs, latest published 2026-10-09. CVSS is the first available of v4.0, v3.1, v3.0, v2 as stored by Stenwatch.	Severity, publication date	Publication date yes; CVSS is today's value

All feeds are public and were downloaded with Stenwatch's own collector (cti/collect.py; the gap fill used tools/nvd_fill.py, which uses the same parser). CVEs with no CVSS score (24,825 across all windows, 1.6%) are treated as severity 0, which only hurts the CVSS baselines.

Data audit. Before the final run the database was checked against NVD's yearly volumes and found to be missing most of 2024 and 2025 (26 and 869 records). It was completed, and the self-check in section 9 now refuses to run if either year has fewer than 30,000 CVEs. Records per year in the database used: 2022: 26,431, 2023: 28,352, 2024: 40,704, 2025: 49,972, 2026: 78,161.

5. Method

5.1 Design

Six consecutive, non-overlapping windows of 180 days (figure 1). At each origin date T0 we rebuild the situation of a team on that day: which CVEs existed, how severe they looked, what EPSS said, and which were already known to be exploited. We then look forward 180 days and see which CVEs were added to KEV. Non-overlapping windows keep one exploited CVE from being counted twice.

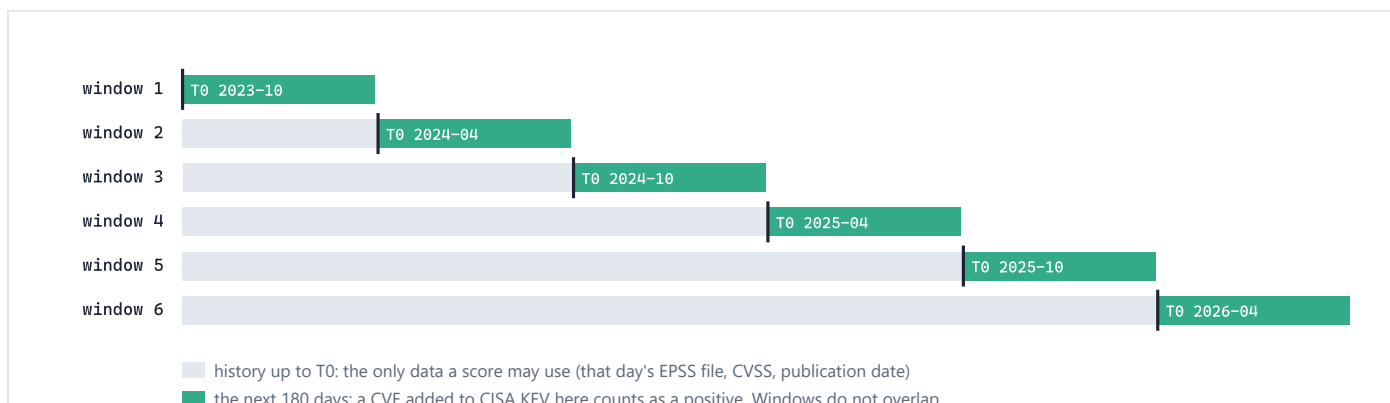


Figure 1. Backtest design. Grey: history available at T0. Green: the 180 days used to label outcomes.

5.2 Population and labels

- **Population at T0:** every CVE published on or before T0, with an EPSS score on T0, and *not yet in KEV on T0*. Already-exploited CVEs are excluded because ranking them is not a prediction.
- **Positive:** a member of that population added to KEV during the next 180 days. Everything else in the population is a negative.

Of the 711 CVEs added to KEV during the six windows, **257** (36%) are in scope. The rest cannot be scored on the origin day: 444 were published after T0, 9 are not in the NVD copy, and 1 had no EPSS score on T0.

5.3 What is compared

Name	How it works
Stenwatch score	EPSS × CVSS: the part of the product's risk formula (likelihood × impact) that can be reproduced without KEV, threat-group or asset information. The weights are constants and do not change the order.
EPSS alone	Rank by exploit probability.
CVSS alone	Rank by severity: what most vulnerability lists do.
Attend queue	EPSS at or above 0.1 (the product's Attend threshold for CVEs not yet known to be exploited).
Attend + Track queue	EPSS at or above 0.01, or CVSS at or above 7.0.
CVSS 9 and above, CVSS 7 and above	The two severity lists teams commonly work from.

5.4 Measures and statistics

- **Recall** of a queue and its **size** (the review cost); **hit rate** and **lift**.
- **Gain curve** (figure 3): recall against share reviewed while reading down a ranking. **Reviews to find 50% and 80%** of the positives (median of the six windows). **ROC AUC**: the chance that a

random positive is ranked above a random negative (0.5 is no skill, 1 is perfect).

- **Ties.** CVSS has few distinct values, so many CVEs tie. Ties are resolved by their expected value under random order (exact, no random seed); AUC gives half credit to ties.
- **Intervals.** Pooled recall uses 95% Wilson score intervals.
- **Paired comparison.** Two queues are judged on the same positives, so the difference is tested on the positives only one of them caught, with an exact two-sided binomial (sign) test.
- **Across windows.** AUC is the mean $\pm$ standard deviation of six windows. No test is applied across windows; six is too few.

5.5 Safeguards against looking ahead

Risk	What we did
Using today's EPSS	Each window uses that origin day's own EPSS file.
Using later KEV knowledge	CVEs already in KEV on T0 are removed; only the date added decides outcomes. The KEV flag is never used as a feature.
Using CVEs that did not exist	Only CVEs published on or before T0.
Tuning on the answer	Thresholds are the product's defaults, fixed before the run; section 8 shows how results move if they change.
CVSS revisions	CVSS is today's NVD value, because scores at T0 are not stored. Possible effect: section 7.

6. Results

6.1 The windows

Origin	Population	Positives	KEV additions	Base rate
2023-10-01	212,884	35	87	0.016%
2024-04-01	237,010	31	88	0.013%
2024-10-01	256,907	49	127	0.019%
2025-04-01	269,000	36	104	0.013%
2025-10-01	292,358	59	133	0.020%
2026-04-01	320,064	47	172	0.015%
Pooled	1,588,223	257	711	0.016%

The base rate is the chance that a random not-yet-exploited CVE is added to KEV within six months: about 0.016%. Reading CVEs in random order would find 1% of the positives per 1% of

effort.

6.2 Queues

Queue	Size (share of CVEs)	Positives caught	Recall (95% interval)	Hit rate	Lift over random
Stenwatch Attend (EPSS ≥ 0.1)	6.1%	103 of 257	40% (34% to 46%)	0.106%	6.5x
Stenwatch Attend + Track (EPSS ≥ 0.01 or CVSS ≥ 7.0)	54.9%	232 of 257	90% (86% to 93%)	0.027%	1.6x
CVSS ≥ 9 (critical)	13.0%	92 of 257	36% (30% to 42%)	0.044%	2.7x
CVSS ≥ 7 (high and critical)	48.2%	220 of 257	86% (81% to 89%)	0.029%	1.8x

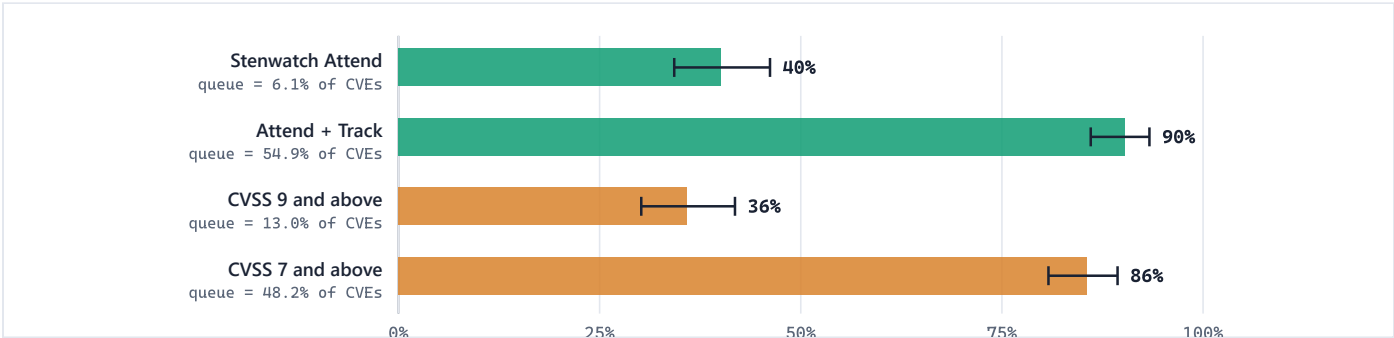


Figure 2. Recall of each queue, pooled over six windows, with 95% intervals.

Paired comparison. Attend against CVSS 9 and above, on the same 257 positives:

	Caught by CVSS 9+	Missed by CVSS 9+
Caught by Attend	45	58
Missed by Attend	47	107

Attend found 58 exploited CVEs the critical list missed; the critical list found 47 that Attend missed (exact test $p = 0.329$). So the two queues largely catch different CVEs, and neither contains the other. Against the much larger CVSS 7 and above list, Attend found 8 that list missed and missed 125 it found (p below 0.001); that list is 7.9 times the size of the Attend queue.

6.3 Rankings

Ranking	AUC (mean ± SD, 6 windows)	Reviews to find 50%	Reviews to find 80%	Found in the first 1%	Found in the first 5%	Found in the first 10%
Stenwatch score (EPSS x CVSS)	0.720 ± 0.055	10.5%	58.2%	21%	37%	46%
EPSS alone	0.692 ± 0.064	10.4%	70.4%	19%	37%	47%
CVSS alone	0.744 ± 0.037	20.1%	42.5%	2%	13%	30%

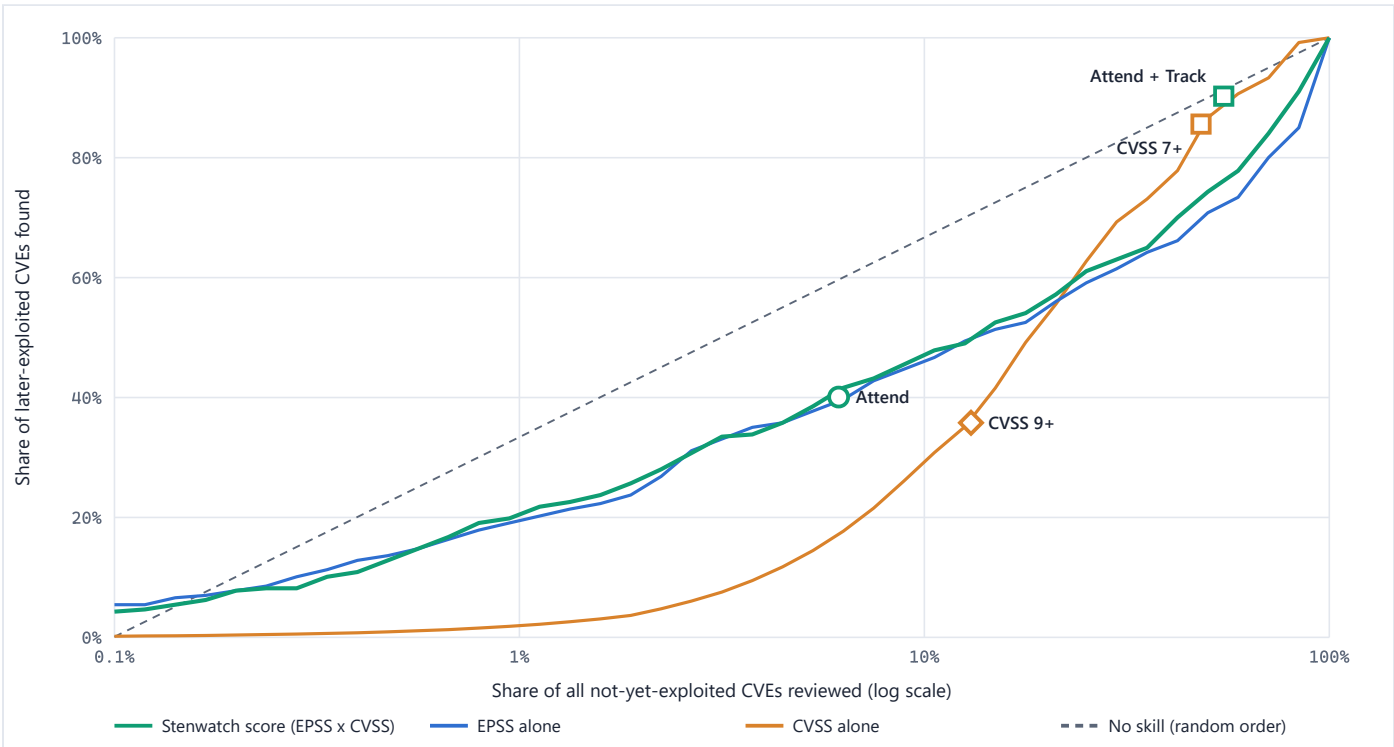


Figure 3. Gain chart. A curve that rises sooner means less work to find the same share of exploited CVEs. The four marked points are the queues of section 6.2.

6.4 Consistency across windows

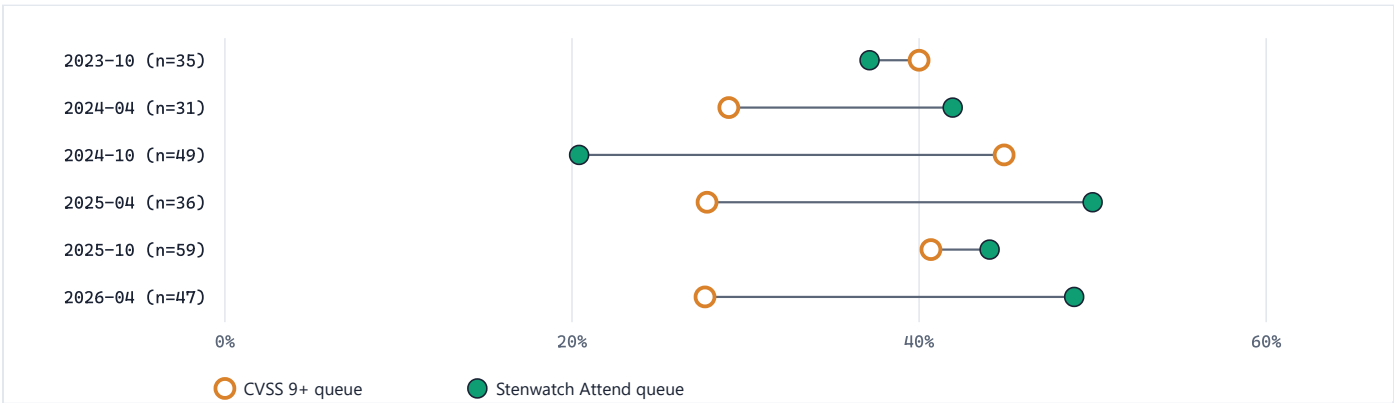


Figure 4. Recall of the Attend queue against the CVSS 9+ queue in each window (n is the number of positives). Attend was higher in 4 of 6 windows.

6.5 At equal queue size (exploratory)

Queues of different sizes are hard to compare, so here every ranking is read down to exactly the size of each queue and its recall is shown beside the queue's own.

Queue size set by	Share of CVEs	Stenwatch score ranking	EPSS ranking	CVSS ranking	The queue itself
Stenwatch Attend	6.1%	41%	40%	16%	40%
CVSS 9 and above	13.0%	50%	49%	36%	36%
CVSS 7 and above	48.2%	72%	70%	86%	86%
Attend + Track	54.9%	76%	72%	89%	90%

Up to a queue the size of the critical list, a probability-led ranking finds many more exploited CVEs than a severity ranking. At the size of the large lists, the CVSS ranking is ahead: 86% against 72% at the size of the CVSS 7+ list. The Attend + Track queue (90%) is no better than simply reading the CVSS ranking to the same size (89%).

6.6 Why severity wins in the tail

45% of the later-exploited CVEs had an EPSS score under 0.01 on the origin day, so they sit in the bottom of any probability ranking and are reached only by reading very far down it. Severity does not depend on prior exploitation signals, which is why it recovers them late. This is the argument for keeping a severity-based second pass behind the Attend queue.

7. Threats to validity and limits

1. **KEV is a proxy for "exploited"**. CISA lists vulnerabilities with evidence of exploitation that are relevant to its mission and have remediation guidance. Exploited CVEs it never lists count here as negatives. The test measures agreement with CISA's list.
2. **Only CVEs that existed on T0 can be scored**. 62% of KEV additions in these windows were published after T0; no ranking could have found them in advance.
3. **Few positives**. 257 in total, between 31 and 59 per window. Single-window figures are noisy. Pooled intervals assume positives are independent, but exploited CVEs often cluster in one product, so the true uncertainty is somewhat larger than shown.
4. **EPSS changed model version** during the period, so scores are not perfectly comparable across windows; section 8 shows sensitivity to the threshold.
5. **CVSS is today's value**. NVD revises scores after publication. If revisions are more likely for CVEs that later prove important, severity is slightly flattered; the bias would favour the CVSS baselines, not Stenwatch.
6. **Not tested here**: the KEV flag, ransomware use, threat-group overlap, asset criticality, internet exposure and supplier context. They have no point-in-time history. In use they act on top of the ranking, so this report tests the part that can be tested and nothing more.

7. **Global, not local.** The queues cover all CVEs. In use, Stenwatch first filters to your own assets, which shrinks the queue by orders of magnitude; the ranking quality measured here carries over, the percentages do not.
8. **An earlier result was wrong.** See the correction in section 1. The self-check on database coverage was added because of it.

8. Sensitivity to the thresholds

Moving the EPSS threshold trades queue size against recall along one curve (figure 5). Lowering the default of 0.1 to 0.05 would add 2.9% of all CVEs to the queue and 4 points of recall; raising it to 0.2 would remove 2.1% of CVEs and 5 points of recall.

EPSS at or above	Queue (share of CVEs)	Recall
0.005	30.35%	60%
0.01	20.60%	55%
0.02	14.38%	50%
0.05	9.02%	44%
0.1 (default)	6.14%	40%
0.2	4.09%	35%
0.3	3.16%	33%
0.5	2.19%	26%

CVSS at or above	Queue (share of CVEs)	Recall
5	82.8%	99%
6	64.3%	93%
7	48.2%	86%
8	22.6%	59%
9	13.0%	36%
9.5	9.9%	30%

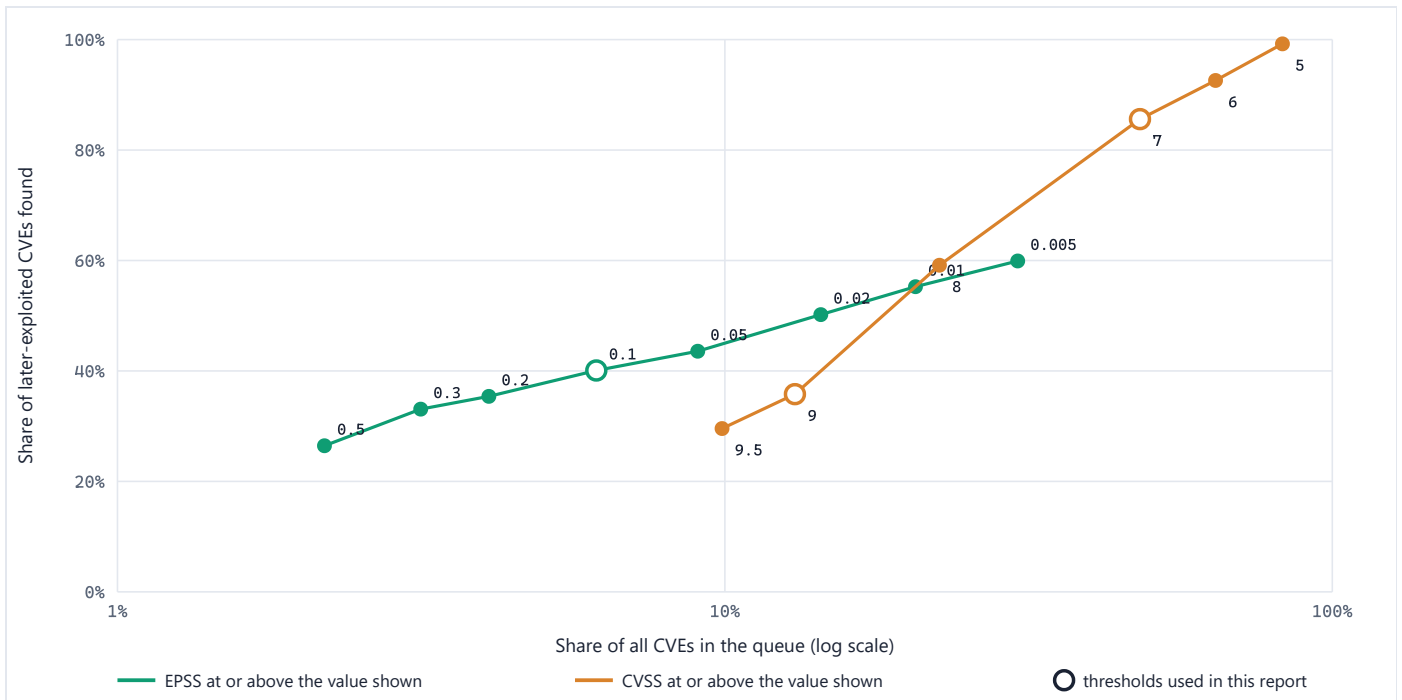


Figure 5. Recall against queue size as each threshold moves. Ringed points are the thresholds used in this report.

9. Reproducibility and checks

Everything is regenerated by commands run from the repository root: `python tools/backtest.py` (downloads six EPSS files, writes docs/backtest/results.json; about a minute once the database is complete), then `python tools/backtest_report.py` (writes this report). The statistics have unit tests with hand-worked answers (`python tools/test_backtest.py`). To complete a database that is missing years, `python tools/nvd_fill.py 2024-01-01 2026-10-09` .

Check	Result
every EPSS snapshot has more than 150,000 scored CVEs	passed
every window has at least 20 positives	passed
no CVE appears twice in a population	passed
positives are a subset of the KEV additions of the window	passed
the six windows do not overlap	passed
Attend queue recall computed by rule equals recall computed through the ranking code (difference < 0.5 positive per window)	passed
a perfect ranking would reach AUC 1 and a tie-only ranking AUC 0.5 (unit tests in tools/test_backtest.py)	passed
queue sizes shrink as thresholds rise (monotone sweeps)	passed
pooled recall never exceeds 1 and the 100 % budget finds every positive	passed
database has complete NVD coverage for 2024 and 2025 (more than 30,000 CVEs per year)	passed

Window origin	EPSS file SHA-256	Rows
2023-10-01	8cad499a66bb048338433f51...	213,894
2024-04-01	c5437dbc2337ea973253ee65...	240,713
2024-10-01	f4ffadaf781caad7dcf6c9b7...	260,671
2025-04-01	87d6744e6bc7b5e3b05095d6...	272,867
2025-10-01	d8a34baffdb8dedfe6c3ce06...	296,333
2026-04-01	1ebc89bb171e7ca54b217c5e...	324,173

Software: Python 3.14.2, NumPy 2.5.3; code revision e7516c9 + uncommitted changes.

10. Conclusions and next steps

1. **Use Attend as the first-pass queue.** It is 2.1 times smaller than the critical list, finds about as many later-exploited CVEs, and each CVE read is 2.4 times as likely to matter.
2. **Do not stop at Attend.** About 60% of later-exploited CVEs sit outside it. Keep a severity-ordered second pass behind it for as long as capacity allows; the Track tier is that pass, and it is large.
3. **Keep the KEV feed fresh.** 62% of CISA additions concern CVEs that did not exist six months earlier; the Act tier, which reacts to KEV, is what covers them.
4. **Re-run every quarter.** New windows add positives and show whether EPSS model changes move the thresholds; the commands above take minutes.

- 5. **Add labels that do not depend on CISA** (public exploit code, vendor advisories noting exploitation) to reduce the proxy problem.
- 6. **Test the local part separately.** Asset context cannot be backtested globally; measure it on your own incidents and patch decisions.

Appendix: per-window detail

Origin	Queue	Size	Positives caught	Recall
2023-10-01	Stenwatch Attend	11,880	13 of 35	37%
2023-10-01	CVSS 9 and above	29,907	14 of 35	40%
2024-04-01	Stenwatch Attend	11,982	13 of 31	42%
2024-04-01	CVSS 9 and above	31,471	9 of 31	29%
2024-10-01	Stenwatch Attend	12,368	10 of 49	20%
2024-10-01	CVSS 9 and above	33,218	22 of 49	45%
2025-04-01	Stenwatch Attend	19,806	18 of 36	50%
2025-04-01	CVSS 9 and above	35,357	10 of 36	28%
2025-10-01	Stenwatch Attend	20,151	26 of 59	44%
2025-10-01	CVSS 9 and above	37,373	24 of 59	41%
2026-04-01	Stenwatch Attend	21,365	23 of 47	49%
2026-04-01	CVSS 9 and above	39,799	13 of 47	28%